Studio Nx

Backend(FastAPI/Python) 94 — 묶음 B 다른 회원의 프로젝트 차단

2026-10-12

Backend(FastAPI/Python) 94 — 묶음 B: 다른 회원의 프로젝트 차단

항목	내용
파일	`studionx/backend/tests/test_phase1_acceptance.py` (묶음 B, 시험 9개)
작업	P1-18 완료 기준 시험: PRD 01 §10의 10번 "다른 회원의 프로젝트는 API로도 조회, 수정, 삭제할 수 없다"
작성	Claude (AI), 2026-10-13, 사용자 검토 (묶음 단위)
이전 · 다음	93 묶음 A · 95 묶음 C (다음)

1. 하는 일

기존 시험은 프로젝트의 **멤버**(편집자, 뷰어)가 무엇을 할 수 있는지를 확인했습니다. 이 묶음은 프로젝트와 **아무 관계가 없는 회원**이 실제로 로그인한 상태에서 무엇을 할 수 있는지를 확인합니다. 소유자와 관계없는 회원은 가입과 로그인을 거쳐 만든 두 계정입니다.

시험	확인하는 것
`test_b1`	관계없는 회원의 조회, 수정, 삭제가 모두 404 `NOT_FOUND`("Project not found.")입니다. 응답에 제목과 설명이 새지 않고, 소유자의 프로젝트는 그대로(제목, 설명, 목록 1건)입니다
`test_b2`	남의 프로젝트와 **없는 번호**의 응답(상태와 본문)이 조회, 수정, 삭제 모두 같습니다. 번호를 바꿔 가며 존재 여부를 알아낼 수 없습니다
`test_b3`	잘못된 본문(`title: null`)으로 수정해도 남의 프로젝트와 없는 번호가 같은 422입니다
`test_b4`	관계없는 회원의 목록, 검색(제목을 정확히 알아도), 대시보드의 최근과 이어 하기 어디에도 소유자의 프로젝트가 없습니다. 소유자에게는 그대로 보입니다
`test_b5`	두 회원이 각자 프로젝트를 만들면 목록은 각자의 것뿐이고, 서로의 번호를 알아도 열리지 않습니다
`test_b6`	토큰이 없거나 잘못된 토큰이면 404가 아니라 401입니다 (조회, 수정, 삭제, 목록 모두)
`test_b7`	리프레시 쿠키 값을 Access Token처럼 써도 프로젝트 API가 열리지 않습니다
`test_b8`	멤버 행을 넣으면 보이고(뷰어는 수정 403), 멤버 행을 지우면 다시 404로 닫힙니다
`test_b9`	소유자가 삭제하면 소유자와 관계없는 회원 모두에게 404이고, 소유자의 대시보드에서도 사라집니다

2. 코드 (뼈대 부분)

```
@pytest.fixture
def two_users(client):
    owner = member_headers(client, "acc_owner")
    stranger = member_headers(client, "acc_stranger")
    created = client.post(PROJECTS, json={"title": "Secret Song", "description": "private"},
                          headers=owner)
    return owner, stranger, created.json()["project_id"]


def assert_project_not_found(res):
    assert res.status_code == 404
    error = res.json()["error"]
```

```
    assert (error["code"], error["message"]) == ("NOT_FOUND", "Project not found.")
    assert "Secret Song" not in res.text and "private" not in res.text
```

B2의 핵심 (같은 응답)

```
foreign = send(f"{PROJECTS}/{pid}")
missing = send(f"{PROJECTS}/999999999")
assert (foreign.status_code, foreign.json()) == (missing.status_code, missing.json())
```

식	뜻
`send(url)`	조회, 수정, 삭제 세 가지를 같은 방식으로 불러 보는 도우미입니다
`foreign`, `missing`	남의 프로젝트에 대한 응답과 없는 번호에 대한 응답입니다
`(상태, 본문) == (상태, 본문)`	둘이 **완전히** 같아야 통과입니다. 문구 한 글자라도 다르면 존재 여부가 새는 것이므로 실패합니다

3. 왜 이렇게

선택	이유
403이 아니라 **404**	403은 "있지만 못 본다"를 알려 줍니다. 사용자 결정(2026-10-08 A안)대로 남의 프로젝트가 있는지조차 알려 주지 않습니다
없는 번호와 응답을 비교	상태 코드만 같아도 본문이나 헤더가 다르면 구분할 수 있습니다. 본문까지 비교합니다
응답에 제목과 설명이 없는지 확인	오류 응답에 내용이 섞이는 실수를 막습니다
잘못된 본문(422)도 확인	FastAPI는 본문 검사를 먼저 하므로, 존재 여부와 관계없이 같은 응답이어야 합니다
토큰 오류는 401	"로그인이 필요함"이지 "권한 없음"이 아닙니다. 404와 섞이면 화면이 잘못된 안내를 합니다
리프레시 쿠키를 Access Token으로 써 보기	두 토큰은 서명 방식이 같아서 구분하지 않으면 재발급 전용 토큰으로 API를 쓸 수 있습니다 (P1-03의 `typ` 구분이 막아 줍니다)
멤버 행을 DB에서 직접 넣고 지움	멤버 초대 기능은 Phase 6이어서 API가 없습니다. 접근 판단이 **멤버 행**에 달려 있다는 것을 직접 확인합니다

4. 시험이 의미 있는지 확인 (일부러 망가뜨리기)

처음부터 통과한 시험이 정말 문제를 잡아내는지 확인하려고, `get_membership`을 "내 멤버 행이 없으면 그 프로젝트의 **아무 멤버나** 인정"하도록 임시로 바꿨습니다.

결과	내용
실패한 시험	B1, B2, B5, B8 (4개)
통과한 시험	나머지 11개 (이 코드가 닿지 않는 시험들)
되돌린 뒤	15개 모두 통과, `app/` 아래에 바뀐 파일 없음

5. 결과

9개 모두 통과했습니다. 코드 수정은 없었고, 기존 코드가 완료 기준 10번을 이미 만족한다는 확인입니다.